

ISO/IEC 27001:2013 Certification Audit Report

Company A - Government Entity
Kingdom of Saudi Arabia

Document Control

Field	Details
Document Title	ISO/IEC 27001:2013 Certification Audit Report & Ce
Certificate Number	IS 720045/KA
Audit Type	Stage 2 Certification Audit (Initial Certification
Audit Date	December 4-8, 2023
Issue Date	January 15, 2024
Expiry Date	January 14, 2027 (3-year certificate)
Certification Body	BSI Group (British Standards Institution)
Classification	PUBLIC (External certification)
Lead Auditor	John Smith, IRCA Certified Lead Auditor (ISO 27001
Audit Team	Sarah Johnson (Technical Specialist - Healthcare),

Table of Contents

- 1. [Certificate of Registration](#certificate-of-registration)
- 2. [Executive Summary](#executive-summary)
- 3. [Audit Scope and Objectives](#audit-scope-and-objectives)
- 4. [Audit Methodology](#audit-methodology)
- 5. [Audit Findings](#audit-findings)
- 6. [ISMS Implementation Evaluation](#isms-implementation-evaluation)
- 7. [Compliance Matrix - ISO 27001:2013 Annex A Controls](#compliance-matrix)
- 8. [Strengths and Opportunities](#strengths-and-opportunities)
- 9. [Certification Decision](#certification-decision)
- 10. [Surveillance Audit Schedule](#surveillance-audit-schedule)
- 11. [Appendices](#appendices)

1. Certificate of Registration

<div style="border: 3px solid #000; padding: 40px; text-align: center; background-color: #f9f9f9;">

CERTIFICATE OF REGISTRATION

This is to certify that the Information Security Management System of:

Company A

Ministry of Health - Government Entity
123 King Fahd Road, Riyadh 12345
Kingdom of Saudi Arabia

Has been assessed and registered by BSI Group as having met the requirements for an effective Information Security Management System in accordance with:

ISO/IEC 27001:2013

Information Security Management Systems - Requirements

Scope of Certification:

The management and operation of information security for:

- Data center services and cloud infrastructure
- Healthcare information systems (Epic EHR, PACS)
- Digital transformation initiatives for government services
- National Data Management Office (NDMO) compliance program
- Personal data protection (PDPL compliance)

Sites Covered:

- Main Data Center: Riyadh, King Fahd Road
- Disaster Recovery Site: Jeddah, Al-Madinah Road
- 5 Regional Hospitals (Riyadh, Jeddah, Dammam, Mecca, Medina)
- 47 Clinics across Kingdom of Saudi Arabia

Certificate Number: IS 720045/KA

Original Registration Date: January 15, 2024

Current Certificate Issue Date: January 15, 2024

Certificate Expiry Date: January 14, 2027

Signed:

John Smith

Global Head of Certification
BSI Group (British Standards Institution)
Registered Office: 389 Chiswick High Road, London W4 4AL, UK
UKAS Accreditation Number: 006

Date of Issue: January 15, 2024

This certificate remains the property of BSI and shall be returned immediately upon request. To check the validity of this certificate, please visit: www.bsigroup.com/clientdirectory

</div>

2. Executive Summary

2.1 Audit Conclusion

CERTIFICATION GRANTED - Company A has successfully demonstrated conformance to the requirements of ISO/IEC 27001:2013.

The audit team conducted a comprehensive Stage 2 Certification Audit from December 4-8, 2023 (5 days, 120 audit hours) across Company A's headquarters, data center, and 6 sampled healthcare facilities. The audit confirmed that Company A has established, implemented, and maintains an effective Information Security Management System (ISMS) that:

- Addresses the context of the organization and stakeholder needs (NDMO, PDPL, healthcare sector)
- Demonstrates leadership commitment with active engagement from CEO and CISO
- Employs risk-based thinking with comprehensive risk assessment process
- Implements appropriate security controls across 14 Annex A control domains
- Monitors and measures performance with robust KPIs and internal audit program
- Pursues continual improvement through management review and corrective actions

2.2 Audit Statistics

Metric	Count
Total Audit Days	5 days (December 4-8, 2023)
Total Audit Hours	120 hours (3 auditors × 40 hours)
Locations Audited	8 (HQ, Data Center, DR Site, 5 hospitals/clinics)
Staff Interviewed	47 employees (from CEO to system administrators)
Documents Reviewed	85 policies, procedures, records
Systems Tested	12 (Epic EHR, CrowdStrike, Splunk, Active Director)
Annex A Controls Assessed	114 controls across 14 domains
Non-Conformities (Major)	0 ■

Non-Conformities (Minor)	0 ■
Observations (Improvement Opportunities)	3 ■
Positive Findings (Strengths)	8 ■

Audit Outcome: RECOMMEND CERTIFICATION (no non-conformities identified)

2.3 Key Strengths

Company A demonstrated the following notable strengths during the audit:

1. Senior Management Commitment: CEO Dr. Abdullah Al-Fahad actively participates in quarterly ISMS management reviews and has allocated significant budget (12.5M SAR/year) for information security.
2. Mature Risk Management: Risk assessment methodology is sophisticated, using FAIR (Factor Analysis of Information Risk) quantitative approach with actuarial data. Risk register contains 124 risks with clear treatment plans.
3. Advanced Technical Controls: Zero Trust Architecture implemented with CrowdStrike EDR, Splunk SIEM, CyberArk PAM, and Azure Sentinel. Security Operations Center (SOC) operates 24/7/365.
4. Healthcare-Specific Security: Epic EHR access controls follow principle of least privilege with Segregation of Duties (SoD) matrix. Patient data encrypted at rest (AES-256) and in transit (TLS 1.3).
5. Comprehensive Training: Annual mandatory security awareness training with 97% completion rate. Phishing simulations conducted quarterly with declining click rates (Q1: 12% → Q4: 3%).
6. PDPL Compliance Integration: ISMS seamlessly integrates Personal Data Protection Law (PDPL) requirements with ISO 27001, demonstrating dual compliance.
7. Incident Response Capability: Security incident response plan tested twice per year with realistic ransomware and data breach scenarios. Mean Time to Detect (MTTD): 8 minutes, Mean Time to Respond (MTTR): 22 minutes.
8. Third-Party Security: Vendor risk assessment process includes contractual security requirements, annual audits, and quarterly security reviews for critical suppliers (Microsoft, Oracle, SAP).

3. Audit Scope and Objectives

3.1 Scope of Certification

Organizational Scope:

- Entity: Company A, Ministry of Health, Kingdom of Saudi Arabia
- Employees: 850 staff (IT: 120, Healthcare: 650, Administration: 80)
- Facilities: Headquarters (Riyadh), 2 Data Centers (Riyadh primary, Jeddah DR), 5 Hospitals, 47 Clinics
- Patients Served: 18.5 million patient records in Epic EHR

Information Security Scope:

The ISMS covers the management and operation of information security for:

1. Healthcare Information Systems:

- Epic EHR (Electronic Health Records) - 18.5M patient records
- Philips PACS (Picture Archiving and Communication System) - medical imaging
- Laboratory Information System (LIS) - lab test results
- Pharmacy Management System - prescription management

2. Enterprise IT Systems:

- Oracle E-Business Suite (EBS) - financial management
- SAP SuccessFactors - human resources
- Microsoft 365 - email, collaboration, productivity
- Active Directory - identity and access management

3. Data Management Infrastructure:

- Informatica Enterprise Data Catalog (EDC) - metadata management
- Informatica Data Quality (IDQ) - data quality monitoring
- Collibra Data Governance Platform - data governance workflows
- AWS S3 + Azure Blob Storage - cloud data lake (hybrid)

4. Security & Compliance:

- CrowdStrike Falcon EDR - endpoint protection
- Splunk Enterprise SIEM - security monitoring
- CyberArk Privileged Access Security - privileged account management
- Varonis DataAlert - data loss prevention (DLP)
- National Data Management Office (NDMO) compliance program (191 controls)
- Personal Data Protection Law (PDPL) compliance program

Exclusions:

- Medical device software (regulated separately by Saudi FDA)
- Physical building infrastructure (managed by Ministry of Public Works)
- Non-IT operational technology (OT) systems (HVAC, elevators)

3.2 Audit Objectives

The Stage 2 Certification Audit aimed to:

1. Verify ISMS Implementation: Confirm that the ISMS documented in Stage 1 audit (September 2023) has been fully implemented and is operational.
2. Assess Conformance: Evaluate conformance to all requirements of ISO/IEC 27001:2013, including:
 - Clauses 4-10 (ISMS requirements)
 - Annex A controls selected in Statement of Applicability (SoA)
3. Test Effectiveness: Verify that security controls are not just documented, but actually effective in managing information security risks.
4. Evaluate Continual Improvement: Assess evidence of monitoring, measurement, analysis, and continual improvement of the ISMS.

5. Make Certification Decision: Recommend whether to grant, defer, or refuse ISO 27001 certification.

4. Audit Methodology

4.1 Audit Approach

Standards Applied:

- ISO/IEC 27001:2013 - Information Security Management Systems - Requirements
- ISO/IEC 27002:2013 - Code of practice for information security controls
- ISO 19011:2018 - Guidelines for auditing management systems

Audit Type: Stage 2 Certification Audit (Initial Certification)

Audit Dates: December 4-8, 2023 (5 consecutive days)

Audit Team:

- Lead Auditor: John Smith, IRCA Certified Lead Auditor (ISO 27001), BSI UK
- Technical Specialist: Sarah Johnson, CISSP, Healthcare IT Security Expert, BSI USA
- Local Auditor: Ahmed Al-Harbi, CISA, BSI Saudi Arabia (language support, local regulation expertise)

Audit Plan: 120 audit hours allocated across:

- Day 1 (Dec 4): Opening meeting, management interviews, document review (24 hours)
- Day 2 (Dec 5): Data center physical inspection, technical controls testing (24 hours)
- Day 3 (Dec 6): Hospital site visits (Riyadh, Jeddah), endpoint security testing (24 hours)
- Day 4 (Dec 7): Process audits (incident response, access management, backup/recovery) (24 hours)
- Day 5 (Dec 8): Findings review, closing meeting, certification decision (24 hours)

4.2 Audit Activities

Document Review (85 documents examined):

- Information Security Policy v3.2
- Risk Assessment & Treatment Plan 2023
- Statement of Applicability (SoA) with 114 Annex A controls
- 32 security procedures (incident response, access control, backup, etc.)
- Internal audit reports (3 audits conducted in 2023)
- Management review meeting minutes (4 quarterly reviews in 2023)
- Security awareness training records
- Vendor security assessment reports

Interviews (47 staff interviewed):

- Executive Level: CEO, CISO, CIO, CFO, Chief Privacy Officer (CPO)
- Management Level: IT Manager, SOC Manager, Data Governance Manager, Legal Counsel
- Technical Level: System Administrators, Database Administrators, Network Engineers, SOC Analysts
- Operational Level: Help Desk Staff, Clinicians (using Epic EHR), HR Staff

Technical Testing (12 systems tested):

- Epic EHR access control testing (role-based access, emergency access procedures)
- CrowdStrike EDR configuration review and threat detection testing
- Splunk SIEM alert rules and incident investigation workflows
- Active Directory password policy, account lockout, privileged account monitoring
- CyberArk PAM password vaulting and session recording
- AWS S3 bucket encryption and access logging
- Azure Blob Storage private endpoints and Azure AD authentication
- VPN remote access (multi-factor authentication with Microsoft Authenticator)
- Backup system testing (Veeam) - recovery time objective (RTO) validation
- Email security (Proofpoint) - phishing detection and quarantine testing
- Data Loss Prevention (Varonis) - sensitive data discovery and blocking rules
- Vulnerability management (Qualys) - patch compliance and vulnerability remediation SLAs

Site Inspections (8 locations):

1. Headquarters (Riyadh): Server room physical security, workstation security, visitor logs
2. Primary Data Center (Riyadh): Biometric access controls, CCTV surveillance, fire suppression (FM-200), environmental monitoring (temperature, humidity), UPS and generator backup
3. DR Data Center (Jeddah): Redundant infrastructure, data replication testing
4. King Fahd Hospital (Riyadh): Nursing station Epic EHR workstations, medication dispensing system security
5. Jeddah General Hospital: PACS workstation security, radiology department access controls
6. Al-Khobar Clinic (Dammam): Wi-Fi security, guest network segregation
7. Remote Worker: VPN connection, endpoint encryption, secure home office setup (sampled 1 employee)
8. Third-Party Vendor (Microsoft Azure Data Center): Reviewed SOC 2 Type II report (in-person visit not conducted, documentary evidence accepted)

4.3 Sampling Methodology

Risk-Based Sampling: Audit focused on high-risk areas:

- Critical systems (Epic EHR, financial systems)
- High-privilege accounts (domain admins, database admins)
- Locations with highest patient volume (Riyadh hospitals)
- Recent security incidents (2 incidents in 2023 - both minor)

Sample Sizes:

- User accounts: 85 accounts reviewed (10% of 850 users)
- Access requests: 50 access requests reviewed (from 2023 JML process)
- Security incidents: All 14 incidents in 2023 reviewed (100%)
- Backup restores: 5 restore tests observed (monthly test schedule)
- Vendor assessments: 12 critical vendors reviewed (from 45 total vendors)

5. Audit Findings

5.1 Non-Conformities

Major Non-Conformities: 0 ■

Minor Non-Conformities: 0 ■

Company A successfully achieved ZERO non-conformities during the Stage 2 Certification Audit. This is a significant accomplishment, particularly for an initial certification audit of an organization of this size and complexity.

5.2 Observations (Improvement Opportunities)

While no non-conformities were identified, the audit team noted 3 observations (improvement opportunities):

Observation 1: Penetration Testing Frequency

Reference: ISO 27001:2013 - Clause 9.2 (Internal Audit), Annex A.12.6.1 (Technical Vulnerability Management)

Finding: Company A conducts external penetration testing annually (last test: March 2023 by Mandiant). While this meets the minimum requirement, industry best practice for healthcare organizations with 18.5M patient records is semi-annual penetration testing.

Evidence Reviewed:

- Penetration test report dated March 15, 2023 (Mandiant)
- No additional penetration test conducted in 2023 (next test planned for Q1 2024)

Risk: Emerging vulnerabilities may remain undetected for up to 12 months.

Recommendation: Consider increasing penetration testing frequency to twice per year (e.g., Q1 and Q3). This would provide more timely identification of vulnerabilities, particularly given the evolving threat landscape in healthcare sector.

Management Response (during audit): CISO acknowledged the recommendation and committed to budget for semi-annual penetration testing starting in 2024 (budget approved: 400,000 SAR/year for 2 annual tests).

Observation 2: Disaster Recovery (DR) Failover Testing Scope

Reference: ISO 27001:2013 - Annex A.17.1.3 (Verify, review and evaluate information security continuity)

Finding: Company A conducts partial DR failover testing quarterly (last test: November 2023). Testing covers database replication and application availability, but does NOT include full user acceptance testing with clinical staff using Epic EHR in DR mode.

Evidence Reviewed:

- Q3 2023 DR test report (November 12, 2023): Database failover successful, Epic EHR available, but no clinician user testing documented
- DR test plan references "technical validation only"

Risk: In a real disaster scenario, clinical staff may encounter usability issues or performance degradation not detected during technical-only testing.

Recommendation: Enhance DR testing to include end-user acceptance testing with a sample of clinicians (e.g., 10 nurses, 5 doctors) performing typical workflows (patient lookup, order entry, medication administration) in DR mode.

Management Response (during audit): IT Manager agreed and will update DR test plan for Q1 2024 test to include 2-hour clinician user acceptance testing window.

Observation 3: Security Awareness Training - Phishing Simulation Reporting

Reference: ISO 27001:2013 - Annex A.7.2.2 (Information security awareness, education and training)

Finding: Company A conducts excellent quarterly phishing simulations with improving results (Q1 2023: 12% click rate → Q4 2023: 3% click rate). However, employees who click on phishing simulation links receive generic feedback email, but are not required to complete remedial training.

Evidence Reviewed:

- Q4 2023 phishing simulation report: 850 emails sent, 26 clicks (3%), 0 credential entries ■
- Follow-up email sent to 26 employees: "You clicked a simulated phishing link. Please be more careful."
- No evidence of mandatory remedial training for clickers

Risk: Employees who repeatedly fall for phishing may not improve without targeted intervention.

Recommendation: Implement mandatory remedial micro-learning (10-minute interactive training module) for employees who click phishing simulations. Track completion rates and analyze whether remedial training reduces repeat clickers.

Management Response (during audit): HR and Security teams agreed to implement remedial training requirement starting Q1 2024 using KnowBe4 platform (already licensed).

5.3 Positive Findings (Strengths)

The audit team identified 8 notable strengths demonstrating exceptional ISMS performance:

Strength 1: CEO Leadership and Security Culture

Evidence: CEO Dr. Abdullah Al-Fahad personally:

- Chairs quarterly Information Security Committee meetings (4 meetings in 2023, 100% attendance)
- Approved 12.5M SAR information security budget for 2024 (15% increase from 2023)
- Delivered opening remarks at annual security awareness week (September 2023, attended by 650 staff)
- Signed Information Security Policy v3.2 (effective January 2023)

Impact: Top-down security culture with visible executive commitment creates accountability and resource availability.

Strength 2: Quantitative Risk Assessment using FAIR

Evidence: Company A uses FAIR (Factor Analysis of Information Risk) methodology with actuarial data:

- Risk register contains 124 risks with Loss Exceedance Curves
- Quantified annualized loss expectancy (ALE) for top risks (e.g., Ransomware ALE: 8.2M SAR)

- Monte Carlo simulation used to model risk aggregation
- Risk-based budget allocation (e.g., 4.5M SAR invested in ransomware prevention controls based on ALE)

Impact: Risk-based decision making with financial justification enables optimal security investment.

Strength 3: Zero Trust Architecture with Micro-Segmentation

Evidence:

- Epic EHR network microsegmented into 12 VLANs (by function: clinician workstations, database servers, API gateway, etc.)
- Palo Alto Next-Gen Firewall enforces least-privilege network policies (1,245 rules documented)
- "Never trust, always verify" - every access request authenticated, authorized, and logged
- Lateral movement blocked: Auditor tested accessing Epic database from clinician workstation → BLOCKED by firewall rule

Impact: Limits blast radius of security incidents and prevents lateral movement by attackers.

Strength 4: Security Operations Center (SOC) with Advanced Analytics

Evidence:

- 24/7/365 SOC staffed with 8 analysts (2 per shift) and 1 SOC Manager
- Splunk Enterprise SIEM ingests 2.5 TB logs/day from 450 log sources
- 85 correlation rules detect advanced threats (e.g., "Lateral movement using PsExec", "Suspicious PowerShell execution")
- User and Entity Behavior Analytics (UEBA) baseline normal behavior, alert on anomalies
- Mean Time to Detect (MTTD): 8 minutes, Mean Time to Respond (MTTR): 22 minutes (Q4 2023 metrics)

Impact: Rapid threat detection and response minimizes potential damage from security incidents.

Strength 5: Privileged Access Management (PAM) with Session Recording

Evidence:

- CyberArk Privileged Access Security deployed with 255 privileged accounts vaulted
- Passwords automatically rotated every 24 hours (9,200 password rotations in 2023)
- All privileged sessions video recorded and stored for 90 days (12,500 sessions recorded in 2023)
- Dual control for ultra-sensitive accounts (e.g., Epic database admin requires approval from 2 people)
- Zero policy violations detected in 2023 ■

Impact: Prevents insider threats and provides forensic evidence for privileged account activity.

Strength 6: Healthcare-Specific Security Controls

Evidence:

- Epic EHR Break-the-Glass emergency access: Requires biometric fingerprint scan + justification text → Audited quarterly (Q4 2023: 42 emergency accesses, all legitimate)
- Role-Based Access Control (RBAC) with 45 roles mapped to 128 Epic security points

- Segregation of Duties (SoD) matrix prevents conflicts (e.g., User who can prescribe opioids cannot also approve refill requests)
- Patient privacy audits: 100% of VIP patient record accesses audited (celebrities, government officials, royal family)

Impact: Balances clinical care urgency with patient privacy protection, specific to healthcare sector needs.

Strength 7: Vendor Risk Management Program

Evidence:

- 45 third-party vendors assessed annually using standardized questionnaire (SIG Lite)
- Critical vendors (Microsoft, Oracle, SAP, Epic) subject to annual on-site audits or SOC 2 Type II report review
- Contracts include security requirements (encryption, incident notification within 24 hours, right to audit)
- Quarterly Business Review (QBR) with critical vendors includes security KPI review

Impact: Extends ISMS to third parties, managing supply chain risk in an interconnected ecosystem.

Strength 8: Integration of PDPL and ISO 27001

Evidence:

- Statement of Applicability (SoA) includes both ISO 27001 Annex A controls AND PDPL-specific controls
- Data Protection Officer (DPO) Noura Al-Mansour participates in Information Security Committee meetings
- Unified risk register addresses both information security risks and personal data protection risks
- Privacy Impact Assessments (PIAs) required for all new systems processing personal data (5 PIAs conducted in 2023)

Impact: Avoids duplicative compliance efforts, demonstrates mature understanding of privacy as a subset of security.

6. ISMS Implementation Evaluation

6.1 Context of the Organization (ISO 27001:2013 - Clause 4)

Conformance: ■ FULLY CONFORMANT

Evidence:

- External Context Analysis: Documented understanding of regulatory landscape (NDMO, PDPL, NCA ECC, ISO 27001), threat environment (ransomware, insider threats, nation-state actors), and stakeholder expectations (patients, Ministry of Health, SDAIA).
- Internal Context Analysis: SWOT analysis identifies strengths (skilled IT team), weaknesses (legacy systems), opportunities (cloud migration), threats (budget constraints).
- Interested Parties: 12 interested parties identified (patients, employees, regulators, vendors, etc.) with their information security requirements documented.
- ISMS Scope: Clearly defined scope statement approved by CEO (see Section 3.1).

Auditor Comment: Company A demonstrates mature understanding of its organizational context, with ISMS scope appropriately tailored to business needs and risk environment.

6.2 Leadership (ISO 27001:2013 - Clause 5)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Top Management Commitment: CEO Dr. Abdullah Al-Fahad signed Information Security Policy v3.2, allocated 12.5M SAR budget, and chairs quarterly Information Security Committee.
- Information Security Policy: Policy v3.2 establishes security objectives, assigns responsibilities, and commits to continual improvement. Policy communicated to all 850 employees via email and posted on intranet.
- Roles & Responsibilities: RACI matrix defines 25 security roles (CISO, SOC Manager, System Admins, etc.) with clear accountabilities.
- Chief Information Security Officer (CISO): Faisal Al-Shehri appointed as CISO with direct reporting line to CEO, independence from IT operations, and authority to halt insecure projects.

Auditor Comment: Exceptional leadership commitment with active CEO involvement creates strong security culture from the top down.

6.3 Planning (ISO 27001:2013 - Clause 6)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Risk Assessment: Comprehensive risk assessment conducted in Q2 2023 using FAIR methodology. 124 risks identified across 8 risk categories (Confidentiality, Integrity, Availability, Compliance, Reputation, Financial, Operational, Strategic).
- Risk Treatment: Risk treatment plan documents 85 security controls implemented to treat 124 risks. Residual risk reviewed and accepted by CEO (signed Risk Acceptance Form dated September 15, 2023).
- Statement of Applicability (SoA): SoA v2.1 documents 114 Annex A controls: 102 applicable, 12 excluded with justification (e.g., A.6.2.2 Teleworking excluded because Company A prohibits teleworking with patient data).
- Information Security Objectives: 8 SMART objectives established (e.g., "Achieve 95% security awareness training completion by December 2024" - ACHIEVED at 97%).

Auditor Comment: Risk management process is sophisticated, using quantitative FAIR methodology with actuarial data for financial modeling.

6.4 Support (ISO 27001:2013 - Clause 7)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Resources: 12.5M SAR budget allocated, 120 IT staff (including 8 dedicated SOC analysts), state-of-the-art security tools (CrowdStrike, Splunk, CyberArk).
- Competence: Job descriptions require security certifications for key roles (CISO: CISSP required, SOC Analysts: CEH or Security+ required). 15 staff hold professional certifications (5 CISSP, 3 CISA, 2 CEH, 5 CompTIA Security+).

- Awareness Training: Annual mandatory security awareness training (30-minute e-learning) with 97% completion rate. Quarterly phishing simulations with declining click rates (Q1: 12% → Q4: 3%).
- Communication: Security intranet portal, monthly security newsletter, quarterly all-hands security updates from CISO.
- Documented Information: 85 security documents (policies, procedures, records) maintained in SharePoint with version control, access controls, and backup.

Auditor Comment: Company A invests significantly in people, processes, and technology to support the ISMS.

6.5 Operation (ISO 27001:2013 - Clause 8)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Operational Planning: Annual security roadmap with quarterly milestones (2023 roadmap: 85% completed).
- Risk Assessment & Treatment: Risk assessment updated quarterly (Q1, Q2, Q3, Q4 2023). New risks added, obsolete risks retired, treatment effectiveness measured.
- Control Implementation: 102 Annex A controls implemented per SoA. Sample testing of 25 controls confirmed effective operation (see Section 7).

Auditor Comment: ISMS is operationalized with regular risk assessment updates and control effectiveness monitoring.

6.6 Performance Evaluation (ISO 27001:2013 - Clause 9)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Monitoring & Measurement: 32 security KPIs tracked monthly (e.g., Mean Time to Detect, Patch Compliance Rate, Phishing Simulation Click Rate). KPI dashboard reviewed by CISO weekly.
- Internal Audit Program: 3 internal ISMS audits conducted in 2023 (Q1, Q2, Q4) by independent internal audit team. Total: 0 major findings, 2 minor findings (both corrected within 30 days).
- Management Review: 4 quarterly management review meetings in 2023 (March, June, September, December) chaired by CEO. Minutes document review of KPIs, audit results, incidents, changes to risk environment, and decisions for continual improvement.

Auditor Comment: Robust monitoring and measurement provides visibility into ISMS performance, enabling data-driven decision making.

6.7 Improvement (ISO 27001:2013 - Clause 10)

Conformance: ■ FULLY CONFORMANT

Evidence:

- Nonconformity & Corrective Action: 14 security incidents in 2023, all investigated with root cause analysis. 2 incidents required corrective actions (both implemented and verified effective).

- Continual Improvement: 8 security improvement initiatives completed in 2023 (e.g., implemented CyberArk PAM, upgraded Splunk to version 9.1, deployed Varonis DLP). Management review meeting minutes document decisions to pursue improvements based on performance data.

Auditor Comment: Company A demonstrates commitment to continual improvement with evidence-based decision making from management reviews.

7. Compliance Matrix - ISO 27001:2013 Annex A Controls

7.1 Annex A Control Evaluation Summary

Annex A Domain	Controls in SoA	Tested	Conformant	Non-Conformant
A.5: Information Security Policies	2	2	2 ■	0
A.6: Organization of Information Security	5	5	5 ■	0
A.7: Human Resource Security	6	4	4 ■	0
A.8: Asset Management	10	6	6 ■	0
A.9: Access Control	14	10	10 ■	0
A.10: Cryptography	2	2	2 ■	0
A.11: Physical & Environmental Security	5	8	8 ■	0
A.12: Operations Security	14	9	9 ■	0
A.13: Communications Security	7	5	5 ■	0
A.14: System Acquisition, Development, Maintenance	10	7	7 ■	0
A.15: Supplier Relationships	5	4	4 ■	0
A.16: Information Security Incident Management	7	5	5 ■	0
A.17: Business Continuity Management	4	4	4 ■	0
A.18: Compliance	8	6	6 ■	0
TOTAL	114	77	77 ■	0

Summary: All 77 tested Annex A controls were found to be CONFORMANT. No non-conformities identified.

(Note: Not all 114 controls were tested during the 5-day audit. Risk-based sampling focused on high-risk controls and critical systems. The remaining 37 controls will be tested during surveillance audits over the 3-year certification cycle.)

7.2 Sample Control Testing Evidence

A.9.2.3: Management of Privileged Access Rights

Test: Reviewed list of users with Epic EHR "Security Administrator" role (highest privilege).

Evidence:

- 3 users have Epic Security Administrator role: CISO, IT Manager, Epic System Admin
- Access requests approved by CEO (documented in ServiceNow tickets)
- Quarterly User Access Reviews (UAR) conducted (Q4 2023 review: all 3 accounts justified and retained)
- CyberArk PAM tracks all privileged session activity (12,500 sessions recorded in 2023)

Result: ■ CONFORMANT - Privileged access follows least privilege principle with executive approval and quarterly review.

A.12.4.1: Event Logging

Test: Verified security event logs collected from Epic EHR, Active Directory, and AWS S3.

Evidence:

- Splunk SIEM ingests logs from 450 sources (Epic, AD, AWS, Azure, CrowdStrike, firewalls, etc.)
- Log retention: 13 months online, 7 years in cold storage (compliance with PDPL and NDMO requirements)
- Tested sample Epic EHR login event: Username, timestamp, source IP, action, result (success/failure) all captured
- Logs protected from tampering: Write-once S3 buckets with versioning enabled

Result: ■ CONFORMANT - Comprehensive logging with appropriate retention and protection.

A.17.1.2: Implementing Information Security Continuity

Test: Reviewed Business Continuity Plan (BCP) and observed Q3 2023 disaster recovery test.

Evidence:

- BCP v2.3 documents recovery procedures for 15 critical systems
- Recovery Time Objective (RTO): 4 hours for Epic EHR
- Recovery Point Objective (RPO): 15 minutes for Epic EHR (database replication)
- Q3 2023 DR test (November 12, 2023): Epic EHR database failed over from Riyadh to Jeddah DR site in 58 minutes (well within 4-hour RTO)

Result: ■ CONFORMANT - Disaster recovery procedures documented and tested, with objectives met during test.

Note: Observation 2 identified improvement opportunity to add end-user acceptance testing to DR tests.

A.18.1.5: Regulation of Cryptographic Controls

Test: Reviewed encryption standards and verified encryption enabled for Epic EHR database.

Evidence:

- Encryption Standards v1.6 document specifies:
 - Data at rest: AES-256
 - Data in transit: TLS 1.3 (minimum TLS 1.2)
 - Key management: AWS KMS with annual key rotation
- Tested Epic EHR production database (Oracle): Transparent Data Encryption (TDE) enabled with AES-256

- Tested Epic web portal: TLS 1.3 with ECDHE_RSA cipher suite, 2048-bit certificate from DigiCert

Result: ■ CONFORMANT - Strong encryption implemented for sensitive healthcare data at rest and in transit.

8. Strengths and Opportunities

8.1 Summary of Strengths (8 identified)

Company A's ISMS demonstrates maturity and sophistication:

1. CEO Leadership - Active executive engagement with visible security culture
2. Quantitative Risk Assessment - FAIR methodology with financial modeling
3. Zero Trust Architecture - Network micro-segmentation and least privilege
4. 24/7 SOC - Advanced threat detection with 8-minute MTTD
5. CyberArk PAM - Privileged account protection with session recording
6. Healthcare-Specific Controls - Break-the-Glass access, SoD matrix for clinicians
7. Vendor Risk Management - Comprehensive third-party security program
8. PDPL Integration - Unified compliance approach for privacy and security

8.2 Summary of Observations (3 identified)

Opportunities for continual improvement:

1. Penetration Testing Frequency - Increase from annual to semi-annual (budget approved for 2024)
2. DR Testing Scope - Add end-user acceptance testing to quarterly DR tests (committed for Q1 2024)
3. Phishing Simulation Follow-Up - Implement mandatory remedial training for clickers (starting Q1 2024)

9. Certification Decision

9.1 Recommendation

CERTIFICATION GRANTED ■

The audit team unanimously recommends GRANTING ISO/IEC 27001:2013 certification to Company A.

Justification:

- Zero non-conformities identified during 120-hour Stage 2 audit
- All tested Annex A controls found to be effective and operational
- ISMS demonstrates mature implementation with sophisticated risk management, advanced technical controls, and strong security culture
- Company A has demonstrated commitment to continual improvement with management acceptance of 3 observations and planned corrective actions for 2024

9.2 Certificate Details

Certificate Number: IS 720045/KA

Issue Date: January 15, 2024

Expiry Date: January 14, 2027 (3-year certificate)

Accreditation: UKAS (United Kingdom Accreditation Service) - Accreditation Number 006

Certification Body: BSI Group (British Standards Institution)

Surveillance Audit Schedule:

- Year 1 Surveillance: December 2024 (12 months after certification)
- Year 2 Surveillance: December 2025 (24 months after certification)
- Recertification Audit: Q4 2026 (prior to January 2027 expiry)

10. Surveillance Audit Schedule

10.1 3-Year Certification Cycle

ISO 27001 certification is valid for 3 years (January 15, 2024 - January 14, 2027), subject to successful surveillance audits.

Audit Type	Scheduled Date	Duration	Focus Areas
Stage 1 (Pre-Audit)	September 2023	2 days	■ Completed - Document review, readiness assessment
Stage 2 (Certification Audit)	December 4-8, 2023	5 days	■ Completed - Full ISMS assessment, control testing
Year 1 Surveillance	December 2024	2 days	Management review, internal audit results, incidents
Year 2 Surveillance	December 2025	2 days	Risk assessment updates, new controls, regulatory changes
Recertification Audit	November 2026	3 days	Full ISMS reassessment (similar scope to Stage 2 audit)

10.2 Surveillance Audit Requirements

To maintain certification, Company A must:

1. Submit Annual Declaration: Confirm ISMS scope, organizational changes, and major incidents (due 30 days before each surveillance audit).
2. Maintain ISMS: Continue operating ISMS in accordance with ISO 27001:2013 requirements (Clauses 4-10, Annex A controls).
3. Internal Audits: Conduct minimum 2 internal ISMS audits per year covering all scope areas over 2-year cycle.
4. Management Reviews: Conduct minimum 2 management reviews per year with top management participation.

5. Notify BSI of Changes: Report significant changes within 30 days:
- Change in ISMS scope (new locations, systems, or services)
 - Major security incidents (breach of 10,000+ patient records)
 - Organizational changes (acquisition, merger, change of CISO)
 - Regulatory sanctions or legal actions related to information security
6. Corrective Actions: Implement corrective actions for non-conformities identified in surveillance audits (if any).
7. Logo Usage: Use BSI ISO 27001 certification logo only in accordance with logo usage guidelines (approved marketing materials only, no misrepresentation).

10.3 Special Surveillance (if required)

BSI reserves the right to conduct special surveillance audit (unannounced or short-notice) if:

- Major security incident reported (e.g., ransomware attack, data breach)
- Complaint received about ISMS effectiveness
- Regulatory sanction or legal action related to information security
- Significant changes to ISMS scope not approved by BSI

11. Appendices

Appendix A: Audit Team Qualifications

Name	Role	Qualifications	Audit Experience
John Smith	Lead Auditor	IRCA Certified Lead Auditor (ISO 27001), 2008-2018	BSI ISO 27001 audits globally, healthcare sector
Sarah Johnson	Technical Specialist	CISSP, CISM, HCISPP (Healthcare Information Security)	Specializes in healthcare IT security, Epic EHR specialis
Ahmed Al-Harbi	Local Auditor	CISA, CDPSE, SABCA Certified Auditor, BSI-qualified	BSI-qualified auditing in Saudi Arabia, NDMO and PDPL

Appendix B: Audit Schedule (December 4-8, 2023)

Day 1 - December 4, 2023 (Monday):

- 08:00-09:00: Opening Meeting (CEO, CISO, CIO, IT Manager, Legal)
- 09:00-12:00: Management Interviews (CEO, CISO, CPO, CFO)
- 12:00-13:00: Lunch Break
- 13:00-17:00: Document Review (policies, procedures, SoA, risk register)
- 17:00-18:00: Audit Team Debrief

Day 2 - December 5, 2023 (Tuesday):

- 08:00-12:00: Data Center Physical Inspection (Riyadh primary site)
- 12:00-13:00: Lunch Break
- 13:00-17:00: Technical Controls Testing (CrowdStrike, Splunk, CyberArk, Active Directory)
- 17:00-18:00: Audit Team Debrief

Day 3 - December 6, 2023 (Wednesday):

- 07:00-08:00: Travel to Jeddah (flight)
- 08:30-12:00: Jeddah DR Data Center Inspection
- 12:00-13:00: Lunch Break
- 13:00-16:00: Jeddah General Hospital Site Visit (Epic EHR workstations, PACS)
- 16:30-18:00: Travel back to Riyadh (flight)

Day 4 - December 7, 2023 (Thursday):

- 08:00-10:00: Incident Response Process Audit (SOC observation, incident investigation)
- 10:00-12:00: Access Management Process Audit (JML process, User Access Review)
- 12:00-13:00: Lunch Break
- 13:00-15:00: Backup & Recovery Process Audit (Veeam testing, DR test review)
- 15:00-17:00: Internal Audit & Management Review Records Review
- 17:00-18:00: Audit Team Debrief and Findings Consolidation

Day 5 - December 8, 2023 (Friday):

- 08:00-10:00: Final Evidence Review and Gap Analysis
- 10:00-11:00: Audit Team Decision Meeting (Certification Recommendation)
- 11:00-12:00: Closing Meeting (Present findings, answer questions, explain next steps)

Appendix C: List of Interviewees (47 staff)

[Sample list - full list available in audit working papers]

1. Dr. Abdullah Al-Fahad - Chief Executive Officer (CEO)
 2. Faisal Al-Shehri - Chief Information Security Officer (CISO)
 3. Khalid Al-Otaibi - Chief Privacy Officer (CPO)
 4. Noura Al-Mansour - Data Protection Officer (DPO)
 5. Layla Al-Harbi - Legal Counsel
 6. Mohammed Al-Zahrani - IT Manager
 7. Sara Al-Mutairi - SOC Manager
 8. Turki Al-Qahtani - SOC Analyst (Shift 1)
 9. Fatima Al-Rashid - SOC Analyst (Shift 2)
 10. Yasser Al-Najjar - Chief Data Officer (CDO)
- ... (continued for all 47 interviewees)

Appendix D: Documents Reviewed (85 documents)

[Sample list - full list available in audit working papers]

Policies (12 documents):

1. Information Security Policy v3.2 (January 2023)
 2. Data Governance Policy v3.1 (March 2024)
 3. Access Control Policy v4.2 (September 2024)
 4. Data Retention & Disposal Policy v2.1 (June 2023)
- ... (continued)

Procedures (32 documents):

1. Security Incident Response Plan v3.0 (October 2024)
2. Data Breach Notification Procedure v2.7 (August 2024)
3. Backup & Recovery Procedures v2.5 (April 2023)
- ... (continued)

Records (41 documents):

1. Risk Assessment & Treatment Plan 2023
2. Statement of Applicability (SoA) v2.1 (September 2023)
3. Internal Audit Report Q1 2023
4. Internal Audit Report Q2 2023
5. Internal Audit Report Q4 2023
6. Management Review Meeting Minutes (Q1, Q2, Q3, Q4 2023)
7. Security Incident Log 2023 (14 incidents)
8. User Access Review (UAR) Report Q4 2023
- ... (continued)

Appendix E: Certification Maintenance Requirements

To maintain ISO 27001:2013 certification, Company A must:

1. ■ Continue operating ISMS in accordance with ISO 27001:2013
2. ■ Conduct minimum 2 internal audits per year
3. ■ Conduct minimum 2 management reviews per year
4. ■ Notify BSI of significant changes (scope, organization, incidents) within 30 days
5. ■ Submit annual declaration 30 days before surveillance audit
6. ■ Participate in surveillance audits (Year 1: December 2024, Year 2: December 2025)
7. ■ Use BSI certification logo in accordance with logo usage guidelines
8. ■ Pay annual certification maintenance fees (due January 15 each year)

Failure to meet requirements may result in:

- Suspension of certification (temporary)
- Withdrawal of certification (permanent)
- Removal from BSI Client Directory (public listing)

END OF AUDIT REPORT

Report Prepared By:

John Smith, IRCA Certified Lead Auditor (ISO 27001)

BSI Group - Middle East Region

Email: john.smith@bsigroup.com

Date: December 15, 2023

Report Reviewed By:

Michael Brown, BSI Certification Manager
BSI Group - Global Headquarters (London, UK)
Email: michael.brown@bsigroup.com
Date: January 10, 2024

Certificate Issued By:

BSI Group (British Standards Institution)
389 Chiswick High Road, London W4 4AL, United Kingdom
UKAS Accreditation Number: 006
www.bsigroup.com

Certification Validity Check:

To verify this certificate is valid and current, visit:
https://www.bsigroup.com/clientdirectory and search for Certificate
Number: IS 720045/KA